

COMPREHENSIVE PENETRATION TESTING AND VULNERABILITY ASSESSMENT REPORT

Cybersecurity Capstone Project

Prepared by: Aravinth Kumar

Assessment: Authorized Web Application Security Lab

Frameworks: OWASP Top 10 and CVSS v3.1

Reporting Year: 2026

CONFIDENTIAL – EDUCATIONAL / AUTHORIZED LAB USE

2. Executive Summary

This report consolidates an authorized security assessment into an executive-ready Vulnerability Assessment and Penetration Testing (VAPT) deliverable. The assessment focuses on common web application risks including injection, cross-site scripting, authentication controls, and cryptographic security.

The assessment demonstrates the complete security lifecycle: scope definition, vulnerability identification, safe validation, evidence collection, risk assessment, remediation planning, and retesting.

Key management priorities

- Remediate confirmed injection and authentication weaknesses before production deployment.
- Use parameterized database queries and context-aware output encoding.
- Strengthen authentication, session management, and abuse-resistance controls.
- Protect cryptographic keys and secrets and use established security libraries.
- Retest all remediated findings and maintain evidence of closure.

3. Scope, Objectives and Rules of Engagement

Scope

- Authorized web application laboratory environment.
- Application-level security controls and selected supporting security mechanisms.
- Testing areas: injection, XSS, authentication, cryptographic controls, and security configuration.

Objectives

- Identify and safely validate security weaknesses.
- Document reproducible evidence without exposing real secrets or personal data.
- Map findings to OWASP categories and assess technical severity using CVSS v3.1.
- Provide prioritized remediation and a repeatable retesting process.

Rules

- Testing is limited to systems for which authorization has been provided.
- No destructive testing, persistence, or denial-of-service activity is required.
- Do not commit credentials, API keys, private keys, tokens, or real user data to GitHub.

4. Assessment Methodology

Phase	Activities
Preparation	Define target, scope, authorization, objectives and evidence requirements.
Reconnaissance	Identify application functionality, inputs, authentication points and exposed components.
Discovery	Review likely weaknesses using manual testing and approved security tools.
Validation	Safely reproduce findings in the authorized lab and record evidence.
Risk Assessment	Assign severity, CVSS metrics and OWASP mapping.
Reporting	Document impact, root cause, evidence and remediation.
Retesting	Verify fixes and check for regressions.

Suggested tools: browser developer tools, Burp Suite Community or OWASP ZAP, application logs, source-code review where available, and Python/Node.js security demonstrations.

5. Risk Rating and CVSS v3.1

CVSSv3.1 provides a standardized technical severity score. The final score must be calculated from the actual conditions observed during testing; the values below are provisional placeholders for the capstone structure.

Score	Severity
0.0	None
0.1–3.9	Low
4.0–6.9	Medium
7.0–8.9	High
9.0–10.0	Critical

Risk Matrix

Impact / Likelihood	Low	Medium	High
Low	Low	Low	Medium
Medium	Low	Medium	High
High	Medium	High	Critical

6. Vulnerability Summary

ID	Finding	OWASP	Provisional CVSS	Severity
VAPT-001	SQL Injection	A03 Injection	8.8*	High
VAPT-002	Cross-Site Scripting	A03 Injection	6.1*	Medium
VAPT-003	Authentication Control Weakness	A07	8.1*	High
VAPT-004	Cryptographic Control Review	A04	5.3*	Medium

* Replace these provisional values with exact CVSS v3.1 scores and vectors derived from the actual lab evidence before mentor submission.

7. Technical Finding – SQL Injection

FindingID:VAPT-001 **Severity:**High(provisional) **OWASP:**A03 – Injection

Description

Insufficient separation between untrusted input and database query syntax can allow query manipulation. The exact affected endpoint and parameter must be recorded from the lab.

Potential Impact

Potential unauthorized database access, disclosure or modification of application data, and authentication bypass in vulnerable designs.

Evidence

Attach the sanitized authorized-lab evidence at **evidence/screenshots/sqli.png**. Do not include real credentials, tokens, private keys, or personal data.

Remediation

Use parameterized queries/prepared statements; avoid string-concatenated SQL; validate server-side input; use least-privileged database accounts; add regression tests.

8. Technical Finding – Cross-Site Scripting

FindingID:VAPT-002 **Severity:**Medium(provisional) **OWASP:**A03–Injection

Description

Untrusted input may be reflected, stored, or inserted into unsafe browser contexts and interpreted as executable content. Record whether the finding is reflected, stored, or DOM-based.

Potential Impact

Potential execution of attacker-controlled content in a victim browser and unauthorized actions depending on application protections.

Evidence

Attach the sanitized authorized-lab evidence at **evidence/screenshots/xss.png**. Do not include real credentials, tokens, private keys, or personal data.

Remediation

Use context-aware output encoding, safe templating, server-side validation, appropriate CSP, and secure cookie attributes.

9. Technical Finding – Authentication Controls

FindingID:VAPT-003 **Severity:**High(provisional) **OWASP:**A07–Identificationand Authentication Failures

Description

Review authentication, credential handling, session management, and abuse resistance. State the exact observed weakness such as weak policy, missing rate limiting, insecure sessions, or bypass.

Potential Impact

Potential unauthorized account access, account takeover, or automated credential abuse.

Evidence

Attach the sanitized authorized-lab evidence at **evidence/screenshots/authentication.png**. Do not include real credentials, tokens, private keys, or personal data.

Remediation

Use secure password hashing, rate limiting, secure session identifiers, logout invalidation, and MFA for high-value accounts where appropriate.

10. Technical Finding – Cryptographic Controls

FindingID:VAPT-004 **Severity:**Medium(provisional) **OWASP:**A04–CryptographicFailures

Description

The capstone includes AES-256-GCM authenticated encryption, RSA-2048 key generation/signing concepts, and HMAC integrity protection. Review implementation and secret handling.

Potential Impact

Weak key/nonce handling or inappropriate cryptographic use can expose confidentiality or integrity.

Evidence

Attach the sanitized authorized-lab evidence at **evidence/screenshots/crypto.png**. Do not include real credentials, tokens, private keys, or personal data.

Remediation

Use established libraries, secure random generation, protected private keys, authenticated encryption, and correct HMAC usage. Never commit secrets.

11. OWASP Mapping

Finding	OWASP Category	Primary Control Focus
SQL Injection	A03 – Injection	Parameterized queries and input handling
XSS	A03 – Injection	Output encoding and safe browser sinks
Authentication	A07 – Identification and Authentication Failures	Authentication, sessions and rate limiting
Cryptographic Controls	A04 – Cryptographic Failures	Encryption, key and secret protection

Mappings should be updated if the actual root cause discovered during testing points to a different category.

12. Prioritized Remediation Guidelines

For Developers

- Replace dynamic SQL with parameterized queries.
- Implement server-side validation and context-aware output encoding.
- Use secure authentication and session-management patterns.
- Remove hard-coded secrets and use secure secret storage.
- Use approved cryptographic libraries and secure key/nonce handling.
- Add security regression tests to CI/CD.

For System Administrators

- Patch operating systems, web servers, databases and dependencies.
- Restrict unnecessary services and network exposure.
- Enforce HTTPS and review TLS configuration.
- Restrict database connectivity with least privilege and network controls.
- Enable centralized logging and monitor security events.

13. Remediation Timeline

Priority	Suggested Target	Actions
Critical	Immediate / 24–72 hours	Contain exposure, emergency fix, verify and retest.
High	Within 7 days	Fix root cause, controlled deployment, retest.
Medium	Within 30 days	Schedule change, validate and document.
Low	Within 60–90 days	Address during maintenance and verify.

These are suggested capstone targets. A real organization should follow its approved vulnerability-management and change-management policy.

14. Retesting and Closure Criteria

A finding should only be marked closed after the original security condition is retested and evidence confirms that the root cause has been addressed.

Status	Meaning
Open	The vulnerability remains reproducible.
Partially Fixed	Some paths are mitigated but the root cause or alternate path remains.
Fixed	The original issue is no longer reproducible and the root cause is addressed.
Risk Accepted	Residual risk is formally accepted by the authorized owner.
Not Applicable	The finding was invalidated by evidence or scope clarification.

Retest record: Finding ID → original evidence → remediation change → retest procedure → result → new evidence → closure date → reviewer.

16. Conclusion

This capstone demonstrates an end-to-end VAPT workflow and converts individual security labs into a professional report suitable for mentor review. The final submission should include verified technical findings, exact CVSS v3.1 vectors, OWASP mappings, sanitized evidence, prioritized remediation, and a GitHub repository.

Final verification before submission

- Confirm the target and testing authorization.
- Replace provisional CVSS values with exact calculations.
- Insert real lab screenshots and affected components.
- Review all remediation guidance for technical accuracy.
- Remove secrets and sensitive information from GitHub.
- Perform and document retesting where fixes are available.